

Gate 0 통과 — GuardianX가 로컬에서 살아났다

12스프린트 0검증의 근본 원인이 해소됐습니다. Code의 ENTRY 정정 4건은 전부 **옳아** 수용하고, 정
정된 WP-2 신뢰 봉인을 착수 승인합니다.

GATE 0 · 경로 A 성공

dj-core 1.1.6 회수 → manage.py check 0 issues → 프론트 빌드 성공

✓ 존속 "시험부" → "회복 확인"

✓ probe DROP (D-245)

✓ 시크릿 게이트 첫 작동

Code 정정 4건 — 전부 수용

착수 전 ENTRY 검토에서 Code의 실측이 지시서 오류 4건을 잡았습니다. 검토개발 게이트가 설계대로 작동한 것입니다. 전부 결정으로 승격합니다(작성자 오류는 D-214 절차대로 기록).

결정	정정 내용	근거 (Code 실측)	작성자 오류
D-246	티켓 ID 재부여 W2-2/3/4 → W0-16/17/18	W2-2/3/4는 정본에 AI 이벤트 센터(2단계 U1)로 이미 존재. 그대 로 두면 U1 티켓 3개가 덮임.	#14 기존 번호 미대조
D-247	R1 순서 정정 역할 분리를 뷰 앞으로	W0-14 현 구현이 superuser 우회를 복제 (tenant_scope.py:165 등 4곳). "전역 superuser" 정의 없이 뷰부터 고치면 두 번 고침.	#15 뷰-우선 순서 지정
D-248	R3 재범위 후처리 계층으로	권한거부 200은 core/role/permission.py:512가 dict 반 환 → \$0.4 금지구역. 소스 수정 불가, 응답 후처리 계층 + 하위호 환 필요.	#16 소스 수정 가정
D-249	EXIT 기준 정정 부착률 → 누출 0건	데코레이터는 표식일 뿐, 좁힘은 핸들러가 함. 652(실측) 라우트 에 전부 붙여도 셀 수 있음. 재현 누출 0건이 기준.	#17 부착률 오정의·466 추정

누적 작성자 오류 17건 — 전부 Code 실측이 착수 전에 잡음. 이것이 검토개발(WP ENTRY 사람검토)의 값입니다. 자동개발이었다면 잘
못된 순서로 뷰를 두 번 고치고, \$0.4 금지구역을 건드리고, "466/466 green"이라는 거짓 완결로 데이터가 새는 채 EXIT됐을 것입니다.

§+ 추가 결정 2건

D-250 P-LOCAL-2 픽스처 승인

활성화하면 빨간불이 켜짐 = 결함을 드러내는 방향(감추는 방향 아님).
D-105 정신 부합. answered.

D-251 포트 노출 (긴급)

운영서버 9200(OpenSearch)·5601(Kibana)이 인터넷에 열림. D-244
IP 제한에 포함 — 자격증명 회전과 동급 긴급.

정정된 신뢰 봉인 — 이대로 착수

ENTRY: 이 문서 붙여넣기(승인) + review/WP-2/ENTRY.md APPROVED 기입. R1 실행 순서가 **역할 분리** → **뷰 스코프** → **백필**로 정정했습니다.

R1 테넌트 격리 봉인

P0 · 입찰 자격

W0-16 superuser 역할 분리 **먼저 ①** (로컬/스테이징만) 13계정 목록화 → "전역 superuser=GAION 운영자 전용" vs 테넌트 운영역할 분리 정의 (W0-14의 전제) → 대체역할 부여 → 자기 테넌트만 보이는지 시험 → 회수 절차서(운영 반영은 대표 승인).

W0-14 뷰 레벨 테넌트 스코프 **②** tenant_scope.py:165 · tenant_filters.py:72 · _check · get_scoped_or_404 등 우회를 "전역 superuser만 통과, 나머지 스코프"로 교체. created_by NULL도 소유 테넌트 귀속. 파일럿 1개 → 확대.

W0-13 created_by 백필 **③** (경로②). 파괴적이므로 **dry-run 리포트 먼저(D-209)**. 뷰 스코프와 독립.

R2 저하 운전

P0 · 운영 신뢰

W0-17 외부 의존 부분 실패 격리. 실측 외부 호출 **29파일 / timeout 없는 49건**. 목록 API가 스트리밍 상태조회 실패 시 500 대신 필드만 "일시 불가"+200. 49건에 타임아웃·폴백. 시험: 외부 다운 모킹 → 목록·이력·통계 200 유지.

R3 API 계약 정합 (재범위)

P0 · 감사·연동

W0-18 응답 후처리 계층에서 200-body-403 → HTTP 403 승격(\$0.4 소스 무수정) + 하위호환 계획. /api/token/pair 문서를 실경로 /api/v1/auth/login로 정정 + delete-session 수정. 계약 테스트 추가.

✓ EXIT 조건 (정정) — 전부 충족 시 제출하고 멈춘다

- 격리: **재현 누출 0건** (현재 15.18.1 → 0) · 격리 시나리오 **5/5** (현재 0/5) — 부착물 아님
- 대체역할 무중단 검증 + superuser 회수 절차서 (운영 반영은 대표 승인 대기)
- 외부 의존 다운 시 핵심 기능 200 유지 green · timeout 없는 49건 처리
- 응답 후처리 계층 + 하위호환 계획 + 계약 테스트 green + 연동 문서 갱신
- 시크릿 0건 · \$0.4 무변경 · 파괴적 변경 dry-run 첨부

긴급 보안 · 승인 · 실행 순서

D-251 운영서버 포트가 인터넷에 열려 있습니다

지금 조치

Code가 확인: 115.21.49.115:9200(OpenSearch, 401 응답) · :5601(Kibana 추정, 응답). 지자체 데이터 검색엔진이 외부에 노출된 상태입니다. 자격증명 회전(D-244)과 동급 긴급으로, 9200-5601을 접근 IP 제한 대상에 포함하십시오. 대표님/운영자가 직접, AI 세션 경유 없이.

§4 대표 승인란

한 줄만 기입

Code가 결정 6건 정서를 마친 뒤, 아래 파일 첫 줄에 기입하시면 WP-2가 착수됩니다.

review/WP-2/ENTRY.md

APPROVED: 2026-08-22 강희석

EXIT 승인은 재현 누출 0건 + 절차서 완성 후 재제출 시점에 별도로 하십니다(D-237). superuser 운영 반영·자격증명 회전·9200/5601 IP 제한은 대표님/운영자가 직접 수행하십니다.

§5 실행 순서

- 1 결정 6건 정서 (D-246~251 decisions.yaml 추가) — 커밋 1개
- 2 WP-2 착수 — R1(W0-16 역활분리 → W0-14 뷰스코프 → W0-13 백필) → R2(W0-17) → R3(W0-18)
- 3 EXIT 5조건(누출 0건 기준) 충족 시 제출하고 멈춘다 — 신규 가치 기능 착수 금지
- 4 대표 EXIT 승인 후 U1~U4 가치 기능(원래 W2-2/3/4 티켓) 단계로 이행

⚡ 긴급 병행(대표/운영자): 자격증명 회전 + 9200-5601 포함 IP 제한 — 착수와 무관하게 지금.

이번 단계의 의미 — GuardianX가 로컬에서 실제로 돈다는 것은 이제 "고칠 수 있다"가 아니라 "고치는 중"이라는 뜻입니다. 남은 것은 남의 지자체가 안 보이게(누출 0건) 만드는 것 하나이고, 그 증거가 곧 다음 지자체 계약의 열쇠입니다.